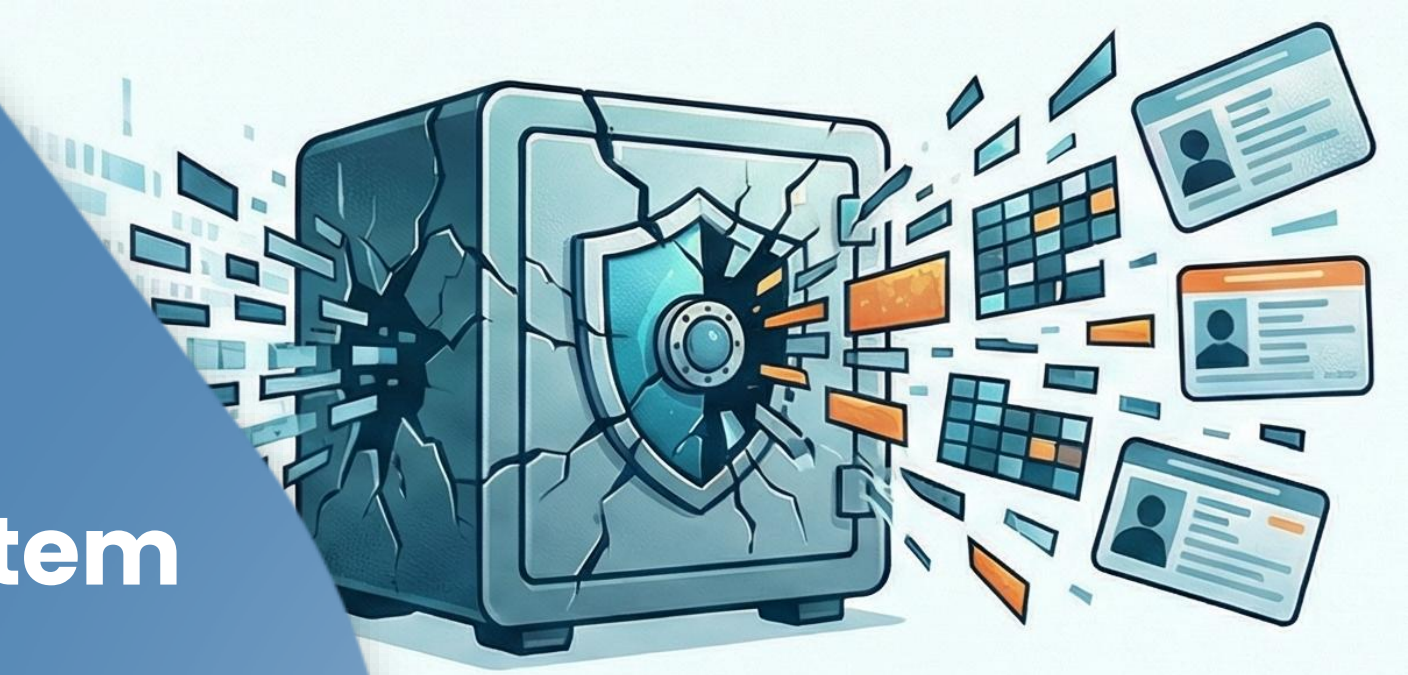
Analisis Pelindungan Data Pribadi pada Sistem Jaminan Kesehatan Nasional (BPJS)



Presented by

Muhammad Alwan Fadhal - 251085045
Hanifah Anis Melinda - 251083013
Herry Marisi Saragi Napitu - 251089087
Kamila - 251089177
Junus Gunawan – 251085025
Muhammad Ichsan Fathillah - 251089112

Pendahuluan & Latar Belakang
Pelindungan Data Pribadi dalam Penyelenggaraan JKN

PDP Sebagai Hak Konstitusional Warga

- Kebocoran data BPJS Kesehatan terjadi pada 2021, melibatkan **dugaan** penjualan data **279 juta WNI (NIK, nama, riwayat Kesehatan & status kematian)** di forum daring oleh peretas bernama 'Coach', BPJS Kesehatan mengklaim sistem keamanannya sudah sesuai standar ISO 27001.
- Pelindungan data pribadi = hak konstitusional (Pasal 28G ayat (1) UUD 1945)
- Sektor kesehatan memproses data paling sensitif

Penyebab Kebocoran Data

Kebocoran data BPJS Kesehatan tahun 2021 mengungkap kelemahan:
- Keamanan sistem
- Tata kelola data
- Pengawasan pihak ketiga

Saat ini regulasi telah ada (UU PDP, UU ITE, PP 71/2019, PM Kominfo 20/2016) namun **implementasi sektor publik belum optimal.** Namun pada saat kejadian **UU PDP belum disahkan, sehingga belum ada sanksi yang mengatur.**

*Secara filosofis, urgensi pelindungan data pribadi juga dapat dipahami melalui **Teori Keadilan Bermartabat**, yang menekankan bahwa hukum harus memanusiakan manusia ("nge wong ke wong") dan menjamin penghormatan terhadap martabat individu, termasuk dalam pengelolaan data pribadi di sektor layanan publik* **(Prasetyo & Karo-Karo, 2020)**.

Rumusan Masalah, Tujuan & Kegunaan

Rumusan Masalah

1. Bagaimana kerangka hukum pelindungan data pribadi yang mengatur kewajiban BPJS Kesehatan sebagai pengendali data?
2. Apa saja permasalahan teknis dan tata kelola yang menyebabkan terjadinya kebocoran data?
3. Bagaimana praktik pelaksanaan pelindungan data dalam penyelenggaraan JKN?
4. Bagaimana harmonisasi peraturan perundang-undangan yang berlaku?

Tujuan dan Kegunaan

Tujuan

- Identifikasi masalah pelindungan data JKN
- Analisis teori & regulasi
- Landasan akademik perbaikan kebijakan

Kegunaan

- Rekomendasi bagi pembuat kebijakan
- Referensi akademik
- Peningkatan tata kelola data sektor kesehatan

Internal

LANDASAN TEORI - KONSEP UTAMA

Teori Privasi & Pelindungan Data Pribadi
Information Privacy (Nasution, 2020)

→ Kemampuan individu untuk menentukan bagaimana, kapan, dan sejauh mana informasi pribadi dikumpulkan, digunakan, dan disebarluaskan

Data Protection: Bentuk khusus pelindungan privasi yang fokus pada:
- Pengumpulan data
- Penyimpanan data
- Pemprosesan data
- Pengungkapan data (dengan aman & sesuai tujuan sah)

Internal

Asas-Asas Dalam UU Pelindungan Data Pribadi (2022)

ASAS	PENJELASAN
Kejelasan Tujuan	Pemprosesan data harus memiliki tujuan yang jelas dan spesifik
Pembatasan Pemrosesan	Data hanya boleh diproses sesuai tujuan yang telah ditentukan
Minimisasi Data	Hanya mengumpulkan data yang benar-benar dibutuhkan
Akurasi	Memastikan data pribadi akurat dan selalu diperbarui
Keamanan	Menjaga keamanan data dari akses, penggunaan, pengubahan tidak sah
Akuntabilitas	Tanggung jawab pengendali data atas semua pemrosesan
Transparansi	Memberikan informasi jelas kepada subjek data

Internal

PERMASALAHAN PRAKTIS - ASPEK TEKNIS
Permasalahan Teknis dalam Penyelenggaraan BPJS Kesehatan

1. Infrastruktur Sistem Informasi Tertinggal
•Masih menggunakan **legacy system** (sistem warisan)
•Tidak dirancang dengan standar keamanan terkini
•Lebih rentan terhadap serangan siber
•Sulit menerapkan kontrol modern: enkripsi, segmentasi jaringan, pemantauan lanjutan

2. Pengamanan Akses Belum Optimal
•Tidak menerapkan prinsip **least privilege**
•Kemungkinan akses berlebihan bagi pihak internal & eksternal
•Membuka celah penyalahgunaan data & kebocoran tidak terdeteksi

3. Pengawasan Pihak Ketiga Lemah
•Vendor teknologi memegang peran penting dalam pemrosesan data
•Pengawasan terhadap partner belum optimal
•Kurangnya standar perjanjian pemrosesan data (Data Processing Agreement)

PERMASALAHAN PRAKTIS - ASPEK KELEMBAGAAN
Permasalahan Tata Kelola & Kelembagaan

4. Peran Data Protection Officer (DPO) Belum Efektif
•Belum diatur secara ketat sebelum UU PDP (2022)
•Belum terintegrasi dalam struktur pengawasan internal
•Fungsi dan akuntabilitas tidak jelas

5. Budaya Keamanan Siber Masih Lemah
• ❌ Minimnya pelatihan keamanan bagi staf
• ❌ Lemahnya prosedur mitigasi risiko
• ❌ Keterbatasan dokumentasi audit keamanan
• ❌ Respons insiden belum terstruktur dengan baik

Internal

KESENJANGAN HUKUM PADA MASA KEBOCORAN DATA BPJS (MEI 2021)

PERIODE	STATUS HUKUM	DAMPAK
2021	Belum ada UU PDP komprehensif	**Kekosongan Hukum Substantif**
Pengaturan Parsial	UU ITE + PP 71/2019	Perlindungan Data Kesehatan **Tidak Spesifik**
UU ITE (2008)	Melarang penggunaan data tanpa persetujuan	Tidak mengatur **sensitivitas data kesehatan**
PP 71/2019	Mewajibkan keamanan data bagi penyelenggara sistem elektronik	Tidak menetapkan **standar teknis rinci** untuk sektor kesehatan

KESIMPULAN TAHUN 2021:

- Indonesia **tidak memiliki payung hukum komprehensif** untuk pelindungan data pribadi
- Pengaturan bersifat **sektoral dan terfragmentasi**
- Mitigasi risiko dan respons insiden **lemah**

Internal

Landasan

Filosofi dari Pancasila:
Sila Kedua dan Kelima

LANDASAN SOSIOLOGIS
Melihat dinamika keadaan masyarakat:

- Digitalisasi Layanan Kesehatan
- Insiden Kebocoran Data BPJS (2021)
- Kesadaran & Tuntutan Masyarakat

Landasan Yuridis:

Internal

Landasan Yuridis

TINGKAT	PERATURAN	FUNGSI
Konstitusi	UUD 1945 Pasal 28G	Dasar hak fundamental privasi
Undang-Undang	UU No. 27/2022 (PDP)	Payung hukum utama pelindungan data
	UU No. 11/2008 (ITE, diubah 2016)	Keamanan transaksi elektronik
Peraturan Pemerintah	PP No. 71/2019	Standar penyelenggaraan sistem elektronik
Peraturan Pelaksana	(Masih dalam proses)	Detil teknis implementasi

Internal

JANGKAUAN & ARAH PENGATURAN (5 Pilar Utama)

NO	ARAH PENGATURAN	DESKRIPSI
1	**Modernisasi Keamanan Informasi**	Penerapan standar teknis ketat, enkripsi, kontrol akses ketat, pemantauan berkelanjutan (mengatasi legacy system)
2	**Standarisasi Tata Kelola Data**	Keseragaman standar: pemetaan data, retensi, pemusnahan data, audit keamanan di seluruh ekosistem JKN
3	**Notifikasi Insiden Batas Waktu**	Paling lambat **72 jam** untuk memastikan transparansi & mitigasi risiko
4	**Mekanisme Kompensasi**	Memberikan hak dan akuntabilitas negara kepada peserta yang terdampak kebocoran
5	**Penguatan Pengawasan Internal**	Penunjukan DPO independen & audit keamanan berkala (internal & independen)

Internal

RUANG LINGKUP MATERI PENGATURAN
Struktur Materi yang Harus Diatur

A. KETENTUAN UMUM

• Definisi: data pribadi, data pribadi spesifik, pengendali data, prosesor data, pemrosesan data, insiden pelanggaran data
• Memberikan batasan untuk penerapan norma berikutnya

B. NORMA SUBSTANTIF

Keamanan Teknis:
• Enkripsi data
• Kontrol akses bertingkat
• Pencatatan aktivitas sistem (audit trail)
• Pemantauan ancaman berkelanjutan
• Prosedur respons insiden

Tata Kelola Data:
• Pemetaan & inventaris data
• Retensi & penghapusan data
• Pengawasan pihak ketiga/vendor
• Kewajiban audit keamanan berkala
• Penunjukan Data Protection Officer

Manajemen Insiden:
• Deteksi dini kejadian keamanan
• Mitigasi & containment
• Pelaporan internal
• Notifikasi kepada peserta & pemerintah
• Mekanisme kompensasi

KETENTUAN SANKSI

Tujuan Sanksi:

- Memastikan kepatuhan terhadap regulasi
- Memberikan efek jera
- Mendorong akuntabilitas lembaga

TINGKAT PELANGGARAN	JENIS SANKSI
Ringan	Teguran administratif
Sedang	Denda administratif
Berat	Pembatasan layanan / penghentian sementara pemrosesan data

Internal

REKOMENDASI KEBIJAKAN

Saran untuk Pemerintah & Institusi

1. **PERCEPATAN REGULASI TURUNAN**
   📋 Pemerintah perlu **mempercepat penerbitan** seluruh aturan pelaksana UU PDP
   → Memberikan panduan teknis yang jelas untuk implementasi

2. MODERNISASI INFRASTRUKTUR KEAMANAN BPJS KESEHATAN

🔒 Menerapkan **arsitektur keamanan zero trust**

•Asumsi: setiap akses harus diverifikasi, tidak ada "kepercayaan default"

•Mengganti legacy system dengan teknologi terkini

•Implementasi enkripsi end-to-end

3. AUDIT KEAMANAN BERKALA OLEH PIHAK INDEPENDEN

🔍 Wajib dilakukan secara **teratur & berkala**

•Minimal 1x per tahun oleh auditor independen bersertifikat

•Hasil audit dipublikasikan untuk transparansi

•Temuan diikuti dengan action plan perbaikan

4. PENGUATAN PENGAWASAN PIHAK KETIGA

📝 Implementasi **Data Processing Agreement (DPA)** yang ketat

•Setiap vendor harus menandatangani perjanjian pemrosesan data

•Klausul keamanan, tanggung jawab, dan audit harus jelas

•Mekanisme kontrol & verifikasi compliance berkala

Kesimpulan Akhir

RINGKASAN EKSEKUTIF
PROBLEM STATEMENT:
Kebocoran data BPJS Kesehatan (Mei 2021) → 279 juta data peserta terekspos
❌ **Penyebab Root:** Kekosongan hukum komprehensif + lemahnya tata kelola teknis
ANALISIS:
• **Sebelum 2022:** Pengaturan parsial (UU ITE + PP 71/2019) tidak cukup
• **Setelah 2022:** UU PDP (No. 27/2022) tersedia, namun implementasi masih terbatas
• **Permasalahan Multi-Level:** Teknis, kelembagaan, tata kelola, dan supervisi

SOLUSI (5 PILAR):
1. ✅ Modernisasi keamanan informasi (zero trust architecture)
2. ✅ Standarisasi tata kelola data di seluruh ekosistem JKN
3. ✅ Notifikasi insiden maksimal 72 jam
4. ✅ Mekanisme kompensasi bagi peserta terdampak
5. ✅ Penguatan pengawasan internal (DPO + audit independen)

Perlindungan Data JKN: Dari Krisis Menuju Solusi

Masalah Utama: Kebocoran Data BPJS 2021

Akar Penyebab Ganda

Kelemahan Multi-Level

Permasalahan mencakup aspek teknis, kelembogaan, tata kelola, dan supervisi

Solusi 5 Pilar untuk Masa Depan

1. Modernisasi Keamanan Informasi

Menerapkan arsitektur keamanan zero trust dan enkripsi end-to-end.

2. Standarisasi Tata Kelola Data

Menyeragamkan standar pemetaan, retensi, dan audit data di seluruh ekosistem JKN.

3. Notifikasi Insiden Cepat

Mewajibkan pemberitahuan insiden kebocoran data maksimal dalam 72 jam.

4. Mekanisme Kompensasi

Memberikan hak ganti rugi dan akuntabilitas negara kepada peserta yang terdampak.

5. Penguatan Pengawasan Internal

Menunjuk Data Protection Officer (DPO) independen dan melakukan audit keamanan berkala.

Mewajibkan pemberitahuan insiden kebocoran data maksimal dalam 72 jam.

Menerapkan pembertuan insiden kebocoran dan enkripsi end-to-end.

Internal

Thank you!
Köszönöm
Σ' ευχαριστώ!
Teşekkürler
Grazie
Danke
Obrigado
Merci
Tak
Hvala
Mulțumesc
Děkuji vám
Спасибо
Gracias
Bedankt
Dzięki
Thank you!
ありがとう
धन्यवाद
תודה
شكراً
شکریه
سپاسگزارم
谢谢你
Tak
Mulțumesc

Internal